PRD

Clinical Note Taker (PRD)

Attribute	Detail
Product	Theraptly
Feature Name	Clinical Note Taker and Documentation Automation
Version	1.0 (Initial Release)
Date	December 11, 2025
Target User	Licensed Clinical Therapists and Counselors
Status	Draft

1. Goal and Success Metrics

1.1 Goal

To significantly reduce administrative burden for clinicians by automating the session documentation workflow, from secure recording and transcription to AI-driven SOAP/DAP note generation and seamless, compliant EHR integration.

1.2 Success Metrics (KPIs)

Metric	Target
Adoption Rate	75% of active users utilize the note-taker for at least one session per week within 3 months of launch.
Time Saved	15 minutes reduction in average documentation time per session, as measured by user feedback surveys.
EHR Transfer Success Rate	99.9% successful transfer rate of approved notes to integrated EHR systems.
Billing Code Acceptance Rate	>95% acceptance rate of suggested CPT/ICD-10 codes by billing teams/systems.
Compliance	Zero PII/PHI exposure incidents; successful completion of SOC 2 Type 2 audit.

2. Detailed Requirements

2.1 Functional Requirements

ID	Requirement	Description
F-1	Secure Audio Recording	The system must allow for secure, high-quality audio recording via both the Mobile App and a Telehealth Integration component.
F-2	Consent Capture	A mandatory, auditable digital consent sign-off/verbal capture process must precede the recording start. The consent record must be securely time-stamped and linked to the session file.
F-3	Transcription	Utilizes a Specialized ASR Model trained on medical terminology to generate a searchable transcript.
F-4	Clinical Analysis	The system must use LLMs fine-tuned for clinical context to analyze the transcript, mapping dialogue to the structure of a clinical note (S, O, A, P).
F-5	Note Generation	Automatically draft the final SOAP or DAP note structure based on the transcript analysis.
F-6	Clinician Review Interface	Provide a user-friendly web interface allowing the clinician to review, edit, and approve the draft note alongside the original transcript.
F-7	Billing Code Suggestion	Generates a list of suggested CPT/ICD-10 codes based on the service type and documented assessment/plan.
F-8	EHR Integration	The approved final note must be seamlessly and securely pushed to the clinician's designated EHR system. (See 2.2 Technical Requirements for integration method).

2.2 Technical Requirements

ID	Requirement	Description
T-1	Data Encryption	All PHI/PII (audio, transcript, notes) must be secured with End-to-End Encryption (E2EE) in transit and at rest.
T-2	Compliance Foundation	System architecture must be designed to meet all necessary requirements for HIPAA and SOC 2 Type 2 compliance.
T-3	EHR API Strategy	Initial integration will prioritize SMART on FHIR standards (where possible) for modern, secure data exchange with target EHRs (e.g., Epic, Cerner).
T-4	Billing Validation	The billing code suggestion feature must incorporate a Rules Engine Layer to cross-validate suggestions against official coding guidelines before presentation.
T-5	Audit Trail	Implement a comprehensive, immutable audit log that tracks every action on the data: recording start/stop, transcription, note edits, code review, and EHR transfer.
T-6	AI Training Policy	Explicitly enforce a Zero-Data-Training Policy for client PHI. All model improvements must use synthetic or properly de-identified data.

2.3 User Experience (UX) Requirements

ID	Requirement	Description
UX-1	Recording Indicator	A clear, always-visible recording indicator in both the mobile app and telehealth integration to assure the user the session is being captured.

UX-2	Review Flow	The note review interface (F-6) must allow easy side-by-side comparison of the original transcript and the draft note for quick verification.
UX-3	One-Click Approval	The final step must be a clear, unambiguous "Approve and Submit to EHR" button, making the clinician responsible for the final output.

3. Scope (Out of Scope for V1)

- Real-time Live Correction/Coaching: The V1 focus is on post-session note generation, not real-time assistance.
- Billing Submission: We will suggest the codes and send the notes, but V1 will not handle the actual submission or claims processing.
- Integration with more than 3 target EHRs: Initial integration will be focused on the top 3 prioritized EHR systems.

4. Open Questions & Dependencies

Question	Dependency/Owner
EHR Prioritization	Which 3 specific EHR vendors are the most critical to integrate with first?
Mobile OS Support	Will the mobile app support iOS only, Android only, or both initially?
Legal Review	What are the final legal sign-off requirements for the BAA, consent workflow, and data retention policies?

Requirements

PRD

Epic 1: Secure Session Capture and Consent
(Goal: Ensure compliant, high-fidelity input data acquisition.)

User Story	Acceptance Criteria (AC)
US 1.1: As a Clinician, I want to start a session recording from the Theraptly Mobile App, so I can capture in-person conversations.	**AC 1.1.1:** The app must display a "Recording" status indicator immediately upon tap. **AC 1.1.2:** Audio data must be encrypted before transmission. AC 1.1.3: If network connection drops, the app must store the session locally until a secure connection is restored and then automatically upload.
US 1.2: As a Clinician, I need to capture consent before recording, so I remain legally compliant.	**AC 1.2.1:** A mandatory consent screen/modal must appear before recording starts. **AC 1.2.2:** The system must record the clinician's digital confirmation (timestamp, user ID) of consent being obtained. **AC 1.2.3:** The recorded consent confirmation must be permanently linked to the session file.

Epic 2: Core AI Processing and Documentation Draft
(Goal: Transform raw data into structured clinical documentation.)

User Story	Acceptance Criteria (AC)
US 2.1: As a Clinician, I want my session recording to be accurately transcribed, so I have a reliable source text.	**AC 2.1.1:** The ASR transcription engine must achieve >95% word accuracy rate on common medical terms (e.g., Depression, CBT, anxiety). **AC 2.1.2:** Speaker diarization must correctly identify "Clinician" vs. "Patient" with >90% accuracy.

US 2.2: As a Clinician, I want the system to automatically generate a SOAP note draft, so my documentation time is minimized.	**AC 2.2.1:** The generated note must be segmented into S, O, A, P sections. **AC 2.2.2:** The 'Subjective' section must accurately pull all patient-reported symptoms and direct quotes. **AC 2.2.3:** The 'Plan' section must correctly identify and pull next steps/homework assigned to the patient.

Epic 3: Clinician Review, Finalization, and Billing
(Goal: Ensure human oversight, accuracy, and revenue capture.)

User Story	Acceptance Criteria (AC)
US 3.1: As a Clinician, I need an interface to quickly review and edit the draft note, so I can ensure clinical accuracy before submission.	**AC 3.1.1:** (See Detailed Breakdown below)
US 3.2: As a Clinician, I want the system to suggest appropriate CPT/ICD-10 codes, so I don't have to manually look them up.	**AC 3.2.1:** The system must suggest a minimum of one CPT code and one ICD-10 code based on the 'Assessment' and 'Plan' sections. **AC 3.2.2:** Suggested codes must be easily selectable and appear flagged for final approval.
US 3.3: As a Clinician, I want to approve the final note and send it to the EHR, so I can complete my documentation workflow.	**AC 3.3.1:** The system must require a mandatory "Approve and Submit" action before EHR transfer. **AC 3.3.2:** Upon successful transfer, the system must display a confirmation and the EHR-assigned document ID.

⭐ **Detailed Breakdown Example: US 3.1 Clinician Review Interface**

ID	User Story	Acceptance Criteria (AC)
US 3.1	As a Clinician, I need an interface to quickly review and edit the draft note,	**AC 3.1.1:** The review screen must present the full, editable draft SOAP note

	so I can ensure clinical accuracy before submission.	on the right and the corresponding full, read-only transcript on the left. **AC 3.1.2:** Highlighting a section in the draft note (e.g., the 'Assessment') must automatically scroll the transcript to the relevant text source for verification. **AC 3.1.3:** All edits made by the clinician must be captured and logged in the audit trail. **AC 3.1.4:** The interface must clearly show the status as "Draft - Pending Clinician Review" until the user explicitly approves it.

Next Step Suggestion
The next step in refining this PRD is to determine the target EHRs, as this defines the complexity and necessary detail for Epic 4: EHR Integration.
Since I already offered to research this, let's proceed to get the necessary factual information.
What are the top 3 EHR systems used by independent therapists and counselors that Theraptly should target first for integration? I will search for this information now.
This detailed structure is much better suited for a development roadmap. The next critical step is to specify the EHR Integration requirements, which directly impacts the engineering effort.
The research indicates that the most popular and relevant EHR systems for independent mental health practices are:
* SimplePractice
* TherapyNotes
* TheraNest (now Ensora)
Let's use these three as the primary targets for Epic 4.
Here is the new Epic 4 structured with User Stories and Acceptance Criteria based on the industry standard of using FHIR APIs where possible for secure data exchange.

Epic 4: Secure EHR Integration (V1 Targets: SimplePractice, TherapyNotes, TheraNest) (Goal: Seamlessly and securely transfer finalized clinical notes to the clinician's chosen EHR.)

User Story	Acceptance Criteria (AC)
US 4.1: As a Clinician, I want to securely connect Theraptly to my EHR (e.g.,	**AC 4.1.1:** The connection must use OAuth 2.0 (or similar secure standard) for

SimplePractice), so notes can be transferred directly.	authentication, requiring the user's explicit consent to share data. **AC 4.1.2:** The system must only store necessary API keys/tokens, not the clinician's EHR credentials. **AC 4.1.3:** The connection must be tested and validated for the three target EHRs: SimplePractice, TherapyNotes, and TheraNest.
US 4.2: As a Clinician, I want approved notes to automatically transfer to the correct patient chart in my EHR, so I don't have to manually match them.	**AC 4.2.1:** The transfer must use the EHR's native API (preferably a FHIR-compliant API for the document/note resource) to send the SOAP/DAP note as a structured document. **AC 4.2.2:** Patient matching must be attempted first via a unique patient ID (if available), or secondarily via a combination of name and date of birth. **AC 4.2.3:** In case of patient matching failure, the system must hold the note and notify the clinician for manual intervention.
US 4.3: As a Clinician, I need confirmation that my note successfully reached the EHR, so I know my documentation is complete.	**AC 4.3.1:** Upon successful API response from the EHR, the system must log the success and the EHR's internal Document ID. **AC 4.3.2**: The note's status in Theraptly must update to "Submitted to [EHR Name]" and become read-only. **AC 4.3.3:** If the transfer fails (e.g., API error, timeout), the system must log the error, retry a minimum of 3 times, and if failure persists, revert the note status to "Review Complete - Submission Failed" and send an alert to the clinician.

Next Step:

With the core functional Epics and the critical EHR targets defined, the last major component is defining the necessary Compliance and Security requirements that underpin all of the above.

Epic 5: Compliance, Security, and Audit

(Goal: Achieve and maintain HIPAA and SOC 2 compliance across the platform to ensure data integrity, confidentiality, and availability.)

User Story	Acceptance Criteria (AC)
US 5.1: As a System Administrator, I need Role-Based Access Control (RBAC) to ePHI, so I can enforce the HIPAA "minimum necessary" standard.	**AC 5.1.1:** Default user roles (e.g., Clinician, Billing, Admin) must be defined with restricted read/write/delete permissions. **AC 5.1.2:** Only the assigned Clinician and authorized Administrators must have read access to the full, un-de-identified session transcript. **AC 5.1.3:** Changes to user access roles must be logged in the audit trail (T-5).
US 5.2: As an Auditor, I need a Comprehensive Audit Trail for all ePHI activity, so I can respond to security incidents and perform compliance checks.	**AC 5.2.1:** The audit log must be immutable, time-stamped, and retained for a minimum of six years (HIPAA standard). **AC 5.2.2:** Every PHI access event must be logged, including: User ID, Action (View/Edit/Submit), Object (Patient ID, Note ID), Date/Time, and IP Address. **AC 5.2.3:** System must generate real-time alerts for suspicious activity (e.g., multiple failed logins, unusual access patterns).
US 5.3: As a Security Officer, I need all patient data to be encrypted in every state, so I can prevent unauthorized access or disclosure.	**AC 5.3.1:** Data in Transit: All communication must be encrypted using TLS 1.2+ (Transport Layer Security) for secure transmission (e.g., recording upload, EHR transfer). **AC 5.3.2:** Data at Rest: All stored audio files, transcripts, and final notes must be encrypted using an industry-standard algorithm like AES-256 (Advanced Encryption Standard).
US 5.4: As a Compliance Team Member, I need documentation proving we comply with SOC 2 Trust Services Criteria, so we can pass external audits.	**AC 5.4.1:** Security: Implement Web Application Firewalls (WAFs) and Intrusion Detection Systems (IDS). **AC 5.4.2:** Availability: Implement a documented backup and disaster recovery plan with defined Recovery Time Objectives (RTOs). **AC 5.4.3:** Confidentiality/Privacy: Ensure the system supports mandatory de-identification policies for any data used in aggregate analytics or AI model tuning.

Summary of PRD Epics (V1)

Epic	Focus Area	Goal
Epic 1	Session Capture & Consent	Securely capture session audio and mandatory consent.
Epic 2	Core AI Processing	Transcribe, analyze, and automatically draft clinical notes.
Epic 3	Review, Finalization & Billing	Enable clinician review, editing, final approval, and code suggestion.
Epic 4	EHR Integration	Securely connect and transfer approved notes to target EHRs (SimplePractice, TherapyNotes, TheraNest).
Epic 5	Compliance & Audit	Implement mandatory HIPAA and SOC 2 security controls, encryption, and audit logging.

HIPAA Compliance

First, a critical framing point

HIPAA compliance is not about whether data is “stored securely” in general terms. It is about:

- Role-based access
- Minimum necessary principle
- Auditability
- Consent and authorization
- Clear separation of PHI vs non-PHI
- Data lifecycle control

Your flow is directionally reasonable, but several steps as written are non-compliant or underspecified.

---

1. Admin view review

Step 1: “Admin logs on to admin portal”

Compliant if and only if:

- Strong authentication (password + MFA recommended)
- Role is explicitly defined as Covered Entity workforce or Business Associate delegate
- Session timeouts are enforced

Missing but required:

- Admin role definition (owner, supervisor, compliance officer)
- Audit logging of admin access

HIPAA requires you to prove who accessed what and when.

Step 2: “Admin navigates to notetaker section”

This is fine conceptually, but PHI exposure risk begins here.

Requirements:

- Admin view must be configurable to limit PHI visibility
- Many admins should not see raw session content
- Default should be metadata-first, content-second

A common failure:

That violates minimum necessary access.

Step 3: “Admin creates/adds clinicians”

This is compliant only if:

- Clinicians are provisioned as workforce members
- Each clinician has a unique user ID
- No shared credentials
- Access is scoped to assigned patients only

Risk area:

- Sending credentials by email

Emailing credentials is not acceptable unless:

- It is a one-time activation link

- It expires
- It forces password creation on first login

Plain-text credentials over email are a red flag.

Step 4: “Admin creates/adds patients”

This is a major PHI boundary.

Creating a patient record means:

- You are storing identifiers
- You are now handling PHI, not just audio

Required clarifications:

- What identifiers are stored at creation?
- Is this MRN, initials, alias, or full demographic data?
- Who is authorized to create patients?

Best practice:

- Patient records should support pseudonymization
- Admins should not be required to enter full PHI to enable notetaking

---

Step 5: “Admin views session data”

This is the highest-risk step.

HIPAA principle violated by default:

- Admin ≠ clinician

- Admin does not automatically have the right to read notes

You must implement:

- Read-only vs full access separation
- Explicit access grants
- Purpose-based access (audit, supervision, billing)

Without this, enterprise buyers will reject you.

---

2. Clinician view review

Step 1: “Clinician downloads app”

This is fine.

But:

- You must assume the device is personal
- You cannot assume device-level encryption is adequate
- You must design for device loss or compromise

This affects caching and offline behavior.

Step 2: “Launches app”

At this point:

- No PHI should be accessible
- No residual data should be present
- No cached audio should load

This must be explicit in your threat model.

Step 3: “Signs up with credentials sent to email”

This is problematic as stated.

Acceptable pattern:

- Admin sends invitation email
- Clinician clicks secure link
- Clinician sets password
- MFA optional but strongly recommended

Unacceptable pattern:

- Username + password sent via email

This will fail any serious HIPAA review.

Step 4: “Sets up session”

Critical questions:

- How is the patient selected?
- Is patient identity visible or coded?
- Is consent handled?

HIPAA does not mandate written consent for treatment, but:

- Recording audio raises state and country consent laws
- You need explicit product-level consent tracking

Step 5: “Records session”

This is the single most sensitive action.

Required safeguards:

- Clear recording indicator
- Ability to pause or stop
- Explicit consent confirmation (even if one-time per patient)
- Encryption in transit and at rest
- No background recording

Also:

- You must define whether raw audio is stored, for how long, and why

---

Step 6: “Session information (notes, patient) is recorded on admin dashboard”

As written, this is non-compliant.

Correct framing:

- Session artifacts are stored in the system
- Visibility depends on role and permissions
- Admin dashboard should default to summaries and status, not content

You need a visibility matrix, not a flat dashboard.

---

3. Missing but mandatory elements

These are not optional.

1. Audit logs

- Every access to PHI
- Every export
- Every role change

2. Data retention controls

- Audio retention duration
- Note retention duration
- Deletion policies

HIPAA does not mandate deletion timelines, but customers will.

---

3. PHI boundary clarity

You must define:

- What is PHI
- When data becomes PHI
- When it stops being PHI

This affects analytics, AI training, and logging.

---

4. Business Associate Agreements

- You must execute BAAs with customers
- Your cloud vendors must sign BAAs with you

Without this, nothing else matters.

---

4. Summary assessment

What is solid

- Clear role separation intent
- Centralized admin oversight
- Clinician-first workflow
- Reasonable high-level flow

What must be fixed

- Credential delivery method
- Admin access to session content
- Patient identity handling
- Consent and recording controls
- Explicit auditability

Bottom line

Your journey is directionally correct but not HIPAA-ready as written.

With modest but precise changes:

- Invitation-based access
- Role-scoped visibility
- Metadata-first dashboards

- Explicit consent handling

It can be made defensible.

If you want, the next step should be one of:

- A role-permission matrix
- A PHI data flow diagram
- A redlined “HIPAA-safe” version of this journey
- Or a checklist enterprise buyers will use to reject or approve this flow

Say which one you want to do next.